Actividad 14 — Escenario integral

Problema	Principio afectado	Riesgo	Control propuesto
1. Todos los empleados de analítica pueden consultar directamente la tabla clientes	Mínimo privilegio y confidencialidad.	Acceso no autorizado o exposición de datos personales.	Crear roles con permisos limitados y otorgar acceso únicamente a los datos necesarios.
2. El área de analítica consulta datos personales para generar estadísticas mensuales.	Minimización de datos.	Exposición innecesaria de información que no se requiere para los análisis.	Utilizar datos agregados o anonimizados para generar las estadísticas.
3. Los datos se conservan desde hace 12 años sin una política de retención.	Limitación del plazo de conservación.	Acumulación de información innecesaria y mayor impacto ante una filtración.	Establecer una política de retención y revisar periódicamente qué datos deben conservarse o eliminarse.
4. No existe documentación sobre la finalidad de cada dato.	Limitación de la finalidad y responsabilidad.	Los datos pueden utilizarse para propósitos distintos de aquellos para los que fueron recopilados.	Documentar la finalidad de cada campo y las condiciones bajo las cuales puede utilizarse.

5. Los desarrolladores reciben copias completas de la base de datos.	Minimización de datos y mínimo privilegio.	Acceso excesivo a información confidencial por personal que no la necesita.	Proporcionar únicamente conjuntos de datos reducidos y necesarios para las pruebas.
6. Las copias de desarrollo contienen información real de los clientes.	Confidencialidad y privacidad desde el diseño.	Filtración de nombres, correos, teléfonos y otros datos personales durante las pruebas.	Sustituir los datos reales por datos sintéticos o correctamente anonimizados.
7. Marketing utiliza los correos electrónicos para campañas promocionales sin que se especifique una finalidad autorizada.	Limitación de la finalidad y licitud del tratamiento.	Uso de datos para publicidad sin una base legal adecuada o sin respetar las preferencias de los clientes.	Verificar la base legal aplicable, informar sobre el uso promocional y respetar las bajas y oposiciones cuando correspondan.
8. No existe una separación de permisos entre analítica, desarrollo y marketing.	Segregación de funciones y mínimo privilegio.	Que un empleado consulte, copie o utilice información fuera de sus responsabilidades.	Definir roles independientes y asignar permisos de acuerdo con las funciones de cada área.
9. Se almacenan	Minimización de datos.	Identificación de	Excluir esos campos de los conjuntos analíticos

identificadores directos como RFC, nombre, correo y teléfono sin una necesidad documentada para análisis.		clientes y robo de identidad en caso de acceso indebido.	y utilizar identificadores no directamente identificativos cuando sea necesario.
No se menciona la existencia de auditorías de acceso a la base de datos.	Responsabilidad proactiva y trazabilidad.	No poder identificar quién consultó, modificó o extrajo información en caso de un incidente.	Registrar los accesos y operaciones relevantes, revisar los registros y generar alertas ante actividades sospechosas.